

PE02 – Evaluacion del Oficial de Seguridad de la Instalacion

ID Documento: GOYA-PE02-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Gerencia General **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-09-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Gerencia General	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Gerencia General	Gerente General
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye exclusivamente a Gerencia General, el Oficial de Seguridad designado y Auditoria Interna. Cada receptor debe registrar acuse de recibo.

1.3 Relacion con EA-103 v2.1

Este documento cumple con el sub-proceso PE02 de la Guia de Acreditacion EA-103 v2.1 de la Entidad Acreditadora (Subsecretaria de Economia), seccion 4.24. Sus dependencias directas son PS02 (Politica de Seguridad, GOYA-PS02-001) y PE01 (Evaluacion del Personal en Roles de Confianza, GOYA-PE01-001).

Criterio EA-103 4.24	Referencia en este documento
Formacion academica minima (Ing. Civil Informatica o equivalente)	Seccion 3.1
Experiencia profesional minima (5+ anos en seguridad de la informacion)	Seccion 3.2
Certificaciones profesionales	Seccion 3.3
Competencias tecnicas especificas para PSC	Seccion 3.4
Verificacion de antecedentes penales	Seccion 5.1
Verificacion de antecedentes comerciales	Seccion 5.2
Procedimiento de contratacion	Seccion 5
NDA con vigencia post-termino	Seccion 6

1.4 Documentos relacionados

ID Documento	Titulo
GOYA-PS01-001	Analisis de Riesgos
GOYA-PS02-001	Politica de Seguridad de la Informacion
GOYA-PS04-001	Plan SGSI
GOYA-PS07-001	Politica de Seguridad del Personal
GOYA-PE01-001	Evaluacion del Personal en Roles de Confianza
GOYA-PO04-001	Control de Acceso Fisico y Logico

2. Objetivo y Alcance

2.1 Objetivo

Definir el perfil profesional, competencias tecnicas, procedimiento de seleccion, mecanismos de verificacion de antecedentes y esquema de evaluacion del Oficial de Seguridad (OS) del Prestador de Servicios de Certificacion (PSC) Goya Ledger SpA, conforme a los requerimientos de acreditacion EA-103 v2.1 seccion 4.24.

2.2 Alcance

Este documento aplica exclusivamente al cargo de Oficial de Seguridad de la Instalacion del PSC. El OS es el responsable maximo de la seguridad de la informacion dentro del PSC y reporta directamente a Gerencia General.

2.3 Justificación del rol

La Ley 19.799 y su Reglamento DS 181/2002, junto con la Guía EA-103 v2.1, exigen que todo PSC acreditado cuente con un Oficial de Seguridad de la Instalación que garantice la implementación, operación y mejora continua del sistema de gestión de seguridad de la información. El OS es la figura central de confianza del PSC, responsable de que los controles de seguridad protejan la integridad, confidencialidad y disponibilidad de los servicios de certificación.

3. Perfil del Oficial de Seguridad

3.1 Formación académica

Requisito	Detalle
Titulo profesional	Ingeniero Civil Informático, Ingeniero Civil en Computación, Ingeniero Civil Electrónico con especialización en TI, o título profesional equivalente reconocido en Chile
Nivel mínimo	Título profesional de al menos 10 semestres (licenciatura o equivalente)
Formación complementaria deseable	Magister en Seguridad de la Información, Ciberseguridad, Gestión de Riesgos Tecnológicos o disciplina afín
Verificación	Título verificado directamente con la institución emisora. Para títulos extranjeros, se requiere reconocimiento o convalidación por el Ministerio de Educación de Chile

3.2 Experiencia profesional

Requisito	Detalle
Experiencia total	Mínimo 5 años de experiencia profesional en seguridad de la información, ciberseguridad o gestión de riesgos tecnológicos
Experiencia en roles de liderazgo	Mínimo 2 años en cargos de jefatura, coordinación o liderazgo de equipos de seguridad informática
Experiencia en PKI (deseable)	Experiencia demostrable en operación, auditoría o

Requisito	Detalle
	implementacion de infraestructura de llave publica
Experiencia en cumplimiento normativo	Experiencia demostrable en implementacion o auditoria de ISO 27001, ETSI EN 319 411, WebTrust for CAs u otros marcos normativos aplicables a PSC
Verificacion	Experiencia verificada mediante certificados de empleadores anteriores, contratos de prestacion de servicios o cartas de referencia con datos de contacto verificables

3.3 Certificaciones deseables

Las siguientes certificaciones profesionales son deseables para el cargo de OS. Al menos una certificacion de la categoria “Alta prioridad” debe estar vigente al momento de la designacion o ser obtenida dentro de los primeros 12 meses:

Alta prioridad:

Certificacion	Entidad emisora	Vigencia
CISSP (Certified Information Systems Security Professional)	(ISC)2	Renovacion cada 3 anos
CISM (Certified Information Security Manager)	ISACA	Renovacion cada 3 anos
ISO 27001 Lead Auditor	Entidad acreditada por JAS-ANZ, UKAS o equivalente	Segun entidad emisora

Prioridad media:

Certificacion	Entidad emisora	Vigencia
ISO 27001 Lead Implementer	Entidad acreditada	Segun entidad emisora
CRISC (Certified in Risk and Information Systems Control)	ISACA	Renovacion cada 3 anos
CISA (Certified Information Systems Auditor)	ISACA	Renovacion cada 3 anos
CEH (Certified Ethical Hacker)	EC-Council	Renovacion cada 3 anos

Prioridad complementaria:

Certificacion	Entidad emisora	Vigencia
CompTIA Security+	CompTIA	Renovacion cada 3 anos
Certified PKI Professional (CPKIP)	PKI Consortium	Segun programa
CCSP (Certified Cloud Security Professional)	(ISC)2	Renovacion cada 3 anos

3.4 Competencias tecnicas especificas para PSC

El OS del PSC debe demostrar competencia tecnica en las siguientes areas especificas de la operacion de servicios de certificacion:

Criptografia y PKI:

- Conocimiento profundo de criptografia de llave publica: RSA, ECDSA, EdDSA (Ed25519).
- Conocimiento de criptografia post-cuantica: ML-DSA-65, ML-KEM-768, esquemas hibridos de migracion.
- Estandares X.509v3, RFC 5280, perfiles de certificados.
- Operacion y gestion de HSM (Hardware Security Modules) y PKCS#11.
- Protocolos de validacion: OCSP, CRL, CT (Certificate Transparency).

Marco regulatorio PSC:

- Ley 19.799 y Reglamento DS 181/2002.
- Guia de Acreditacion EA-103 v2.1 (todos los sub-procesos PS, PO, PE).
- ETSI TS 102 042 y ETSI EN 319 411-1/2.
- WebTrust Principles and Criteria for Certification Authorities.
- Ley 19.628 (proteccion de datos personales).
- Ley 21.459 (delitos informaticos).

Seguridad operacional:

- Gestion de incidentes de seguridad y respuesta a emergencias.
- Analisis de riesgos y gestion de amenazas (metodologias MAGERIT, ISO 31000, NIST RMF).
- Seguridad de redes: firewalls, IDS/IPS, segmentacion, TLS 1.3.
- Hardening de sistemas operativos y contenedores.
- Continuidad operacional y recuperacion de desastres (BCP/DRP).
- Auditoria de sistemas y analisis forense digital.

Gestion de seguridad:

- Implementacion y operacion de SGSI conforme a ISO 27001.
- Gestion de controles de acceso fisico y logico.
- Clasificacion y manejo de informacion.
- Gestion de vulnerabilidades y programa de parcheo.
- Concienciacion y capacitacion en seguridad del personal.

4. Funciones y Responsabilidades del OS

4.1 Funciones estrategicas

- Diseñar, implementar y mantener el Sistema de Gestion de Seguridad de la Informacion (SGSI) del PSC conforme a ISO 27001 y EA-103 v2.1.
- Asesorar a Gerencia General en decisiones relacionadas con seguridad de la informacion.
- Definir y mantener actualizada la Politica de Seguridad de la Informacion (PS02).
- Dirigir la ejecucion del analisis de riesgos periodico (PS01) y proponer tratamientos.
- Coordinar la preparacion del PSC para auditorias de acreditacion y mantenimiento ante la Entidad Acreditadora.

4.2 Funciones operacionales

- Supervisar la operacion diaria de los controles de seguridad fisicos y logicos.
- Gestionar incidentes de seguridad: deteccion, contencion, erradicacion, recuperacion y leccion aprendida.
- Autorizar y supervisar ceremonias de generacion de llaves criptograficas.
- Aprobar cambios en la configuracion de sistemas criticos del PSC.
- Supervisar la gestion de accesos del personal a sistemas e instalaciones del PSC.
- Coordinar el programa de capacitacion en seguridad (PE01, seccion 6).
- Mantener el registro de activos de informacion y su clasificacion.

4.3 Funciones de cumplimiento

- Verificar el cumplimiento de la CPS, politicas y procedimientos del PSC.
- Coordinar con el Auditor Interno la ejecucion del plan de auditoria.
- Gestionar hallazgos de auditoria y no conformidades: plan de accion, seguimiento y cierre.
- Reportar a Gerencia General el estado de cumplimiento y los indicadores de seguridad.
- Mantener actualizada la documentacion del SGSI conforme a los cambios normativos.

4.4 Funciones de reporte

- Reportar mensualmente a Gerencia General el estado de seguridad del PSC.
 - Reportar inmediatamente incidentes de seguridad criticos.
 - Elaborar el informe anual de seguridad para la Entidad Acreditadora.
 - Documentar las decisiones de seguridad con su justificacion tecnica.
-

5. Procedimiento de Seleccin y Contratacion

5.1 Verificacion de antecedentes penales

Paso	Descripcion	Responsable	Evidencia
1	Solicitar certificado de antecedentes penales emitido por el Servicio de Registro Civil e Identificacion de Chile con fecha no superior a 15 dias	Gerencia General	Certificado original
2	Verificar ausencia de condenas por delitos contra la fe publica, delitos informaticos (Ley 21.459), fraude, estafa, falsificacion, cohecho, lavado de activos y delitos contra la propiedad intelectual	Gerencia General	Informe de verificacion
3	Para candidatos extranjeros, solicitar certificado de antecedentes penales de cada pais donde haya residido en los ultimos 10 anos, apostillado o legalizado	Gerencia General	Certificados apostillados
4	Consultar listas de sancionados internacionales (OFAC, UN, EU)	Gerencia General	Reporte de consulta
5	Documentar resultado en expediente confidencial del candidato	Gerencia General	Expediente sellado

Criterio de rechazo: Se rechazara a cualquier candidato que presente condenas vigentes o extintas por delitos contra la fe publica, delitos informaticos, fraude, falsificacion, cohecho o cualquier delito que comprometa la integridad requerida para el cargo. Dado el nivel de confianza del rol, antecedentes eliminados conforme al DL 409 seran evaluados caso a caso por Gerencia General con asesoria legal.

5.2 Verificacion de antecedentes comerciales

Paso	Descripcion	Responsable	Evidencia
1	Solicitar certificado de antecedentes	Gerencia General	Certificado original con fecha

Paso	Descripcion	Responsable	Evidencia
	comerciales de la Camara de Comercio de Santiago o entidad equivalente		no superior a 15 dias
2	Consultar registros Dicom/Equifax para verificar situacion financiera	Gerencia General	Reporte impreso y fechado
3	Verificar ausencia de participacion como director, socio o representante legal en empresas con quiebra fraudulenta o sanciones regulatorias	Gerencia General	Informe de verificacion
4	Documentar resultado en expediente confidencial del candidato	Gerencia General	Expediente sellado

Criterio de rechazo: Se rechazara al candidato que presente protestos vigentes no aclarados, quiebras en curso, morosidades significativas o vinculacion con empresas sancionadas por organismos reguladores financieros.

5.3 Verificacion de certificaciones profesionales

Paso	Descripcion	Responsable	Evidencia
1	Solicitar copia de certificaciones profesionales vigentes declaradas por el candidato	Gerencia General	Copias de certificados
2	Verificar directamente con la entidad emisora la autenticidad y vigencia de cada certificacion	Gerencia General	Constancia de verificacion por entidad emisora
3	Verificar titulo profesional directamente con la institucion educacional	Gerencia General	Constancia de la institucion
4	Documentar resultado en expediente del candidato	Gerencia General	Expediente actualizado

5.4 Entrevista de seguridad

Paso	Descripcion	Responsable	Evidencia
1	Conformar panel de entrevista: Gerente General, Arquitecto de Sistema y un experto externo en seguridad de la informacion (opcional)	Gerencia General	Acta de conformacion del panel
2	Evaluar conocimientos tecnicos mediante caso practico: respuesta a un incidente de seguridad en un PSC, con analisis de impacto, contencion y recuperacion	Panel de entrevista	Evaluacion tecnica documentada
3	Evaluar conocimiento del marco regulatorio: preguntas sobre EA-103, Ley 19.799, ETSI EN 319 411, ISO 27001	Panel de entrevista	Evaluacion regulatoria documentada
4	Evaluar competencias de liderazgo y comunicacion: escenarios de gestion de equipos bajo presion, comunicacion de incidentes a la alta direccion	Panel de entrevista	Evaluacion de competencias documentada
5	Documentar resultado con puntuacion por competencia (minimo 70% en cada dimension)	Panel de entrevista	Acta de entrevista firmada por panel

Criterio de aprobacion: El candidato debe obtener al menos 70% en cada una de las tres dimensiones evaluadas (tecnica, regulatoria, liderazgo). El panel emite recomendacion unanime o por mayoria.

6. Acuerdo de Confidencialidad (NDA)

6.1 Clausulas obligatorias

El NDA del OS debe incluir, como minimo, las siguientes clausulas:

Clausula	Contenido
Definicion de informacion confidencial	Toda informacion relacionada con la operacion del PSC, incluyendo pero no limitada a: material criptografico, llaves privadas, procedimientos de ceremonias de llaves, configuracion de HSM, arquitectura de seguridad, vulnerabilidades, datos personales de suscriptores, registros de auditoria, planes de continuidad, informacion comercial y estrategica
Obligaciones del receptor	No divulgar, copiar, transmitir ni utilizar la informacion confidencial para fines distintos al cumplimiento de sus funciones. No acceder a informacion que no sea estrictamente necesaria para sus funciones
Propiedad intelectual	Todo desarrollo, procedimiento, documentacion o innovacion generada durante el ejercicio del cargo pertenece a Goya Ledger SpA
Devolucion y destruccion	Al termino de la relacion laboral, devolver toda la informacion confidencial en cualquier soporte y certificar la destruccion de copias personales
Excepciones	Informacion que sea de dominio publico sin mediar incumplimiento del NDA, informacion que deba divulgarse por requerimiento judicial o administrativo (con notificacion previa a Goya Ledger SpA)
Sanciones por incumplimiento	Indemnizacion de perjuicios, clausula penal (monto definido en el contrato), acciones penales conforme a la legislacion chilena
Jurisdiccion	Tribunales ordinarios de Santiago de Chile
Legislacion aplicable	Legislacion chilena,Codigo Civil, Codigo del Trabajo, Ley 19.628, Ley 19.799

6.2 Vigencia post-termino

Aspecto	Condicion
Vigencia general del NDA	Minimo 5 anos contados desde la fecha efectiva de termino de la relacion laboral o contractual
Material criptografico	Vigencia indefinida para toda informacion relativa a llaves privadas, procedimientos

Aspecto	Condicion
Datos personales de suscriptores	de ceremonias, configuracion de HSM y vulnerabilidades criptograficas Vigencia indefinida conforme a Ley 19.628
Vulnerabilidades de seguridad	Vigencia indefinida para toda informacion sobre vulnerabilidades conocidas, incidentes de seguridad y planes de remediacion
Informacion comercial	Minimo 5 anos para informacion estrategica, planes de negocio y acuerdos comerciales
Recordatorio al termino	El OS debe firmar un documento de recordatorio de vigencia del NDA al momento de su desvinculacion, detallando las categorias de informacion sujetas a confidencialidad y sus respectivos plazos

7. Evaluacion de Desempeno del OS

7.1 Indicadores de desempeno

La evaluacion del OS se realiza semestralmente por Gerencia General, utilizando los siguientes indicadores:

Indicador	Meta	Medicion
Disponibilidad de servicios del PSC	>= 99.5% mensual	Reportes de monitoreo
Tiempo medio de deteccion de incidentes (MTTD)	<= 4 horas	Registro de incidentes
Tiempo medio de respuesta a incidentes (MTTR)	<= 8 horas (criticos), <= 24 horas (altos)	Registro de incidentes
Cumplimiento del plan de auditoria interna	>= 90% de las actividades planificadas	Informe de auditoria
Cierre de no conformidades en plazo	>= 85% dentro del plazo acordado	Registro de no conformidades
Ejecucion del programa de capacitacion	>= 90% del personal capacitado	Registros de capacitacion
Actualizacion de documentacion SGSI	100% de documentos dentro de vigencia	Registro documental

Indicador	Meta	Medicion
Ejecucion de simulacros	>= 2 simulacros anuales ejecutados	Informes de simulacro
Vulnerabilidades criticas remediadas en plazo	>= 95% dentro de SLA definido	Reporte de vulnerabilidades
Satisfaccion de Gerencia General	>= 4/5 en evaluacion cualitativa	Evaluacion directa

7.2 Procedimiento de evaluacion

Paso	Descripcion	Responsable	Plazo
1	El OS prepara informe semestral de gestion de seguridad con resultados de cada indicador	Oficial de Seguridad	Ultimos 5 dias habiles del semestre
2	Gerencia General revisa el informe y programa reunion de evaluacion	Gerencia General	Dentro de los 10 primeros dias habiles del semestre siguiente
3	Reunion de evaluacion: revision de indicadores, logros, areas de mejora y plan de accion	Gerencia General + OS	Segun programacion
4	Gerencia General emite evaluacion formal con calificacion global y observaciones	Gerencia General	Dentro de los 5 dias habiles posteriores a la reunion
5	Plan de mejora (si aplica): el OS presenta plan de accion para indicadores bajo meta	Oficial de Seguridad	Dentro de los 10 dias habiles posteriores a la evaluacion

7.3 Acciones ante evaluacion insatisfactoria

Situacion	Accion
1-2 indicadores bajo meta	Plan de mejora con seguimiento mensual durante el semestre siguiente
3-4 indicadores bajo meta	Plan de mejora formal, capacitacion adicional y revision trimestral. Evaluacion extraordinaria a los 3 meses

Situacion	Accion
5 o mas indicadores bajo meta	Evaluacion de continuidad en el cargo. Se activa el procedimiento de reemplazo (seccion 8) si la evaluacion extraordinaria a los 3 meses no muestra mejora
Incidente critico por negligencia demostrable	Suspension inmediata de funciones y evaluacion de desvinculacion por Gerencia General con asesoria legal

8. Procedimiento de Reemplazo del OS

8.1 Causales de reemplazo

- Desvinculacion voluntaria (renuncia).
- Desvinculacion por evaluacion insatisfactoria persistente (seccion 7.3).
- Desvinculacion por causa justificada (negligencia, incumplimiento del NDA, falta de integridad).
- Incapacidad temporal o permanente que impida el ejercicio del cargo.
- Vencimiento de contrato sin renovacion.
- Reestructuracion organizacional.

8.2 Plan de continuidad del rol

Fase	Accion	Plazo	Responsable
1. Designacion interina	Gerencia General designa un OS interino entre el personal de confianza que cumpla al menos los requisitos minimos de formacion y experiencia	Inmediato (dentro de 24 horas)	Gerencia General
2. Traspaso de funciones	El OS saliente (si disponible) realiza traspaso formal: documentacion, credenciales, estado de proyectos, incidentes abiertos, contactos clave	Maximo 10 dias habiles	OS saliente + OS interino
			Operador de Sistemas

Fase	Accion	Plazo	Responsable
3. Revocacion de accesos del OS saliente	Revocar todos los accesos logicos y fisicos del OS saliente conforme a PE01 seccion 8.1	Dentro de las 2 horas de la fecha efectiva de desvinculacion	
4. Proceso de seleccion	Iniciar proceso de seleccion del OS titular conforme a seccion 5 de este documento	Dentro de los 15 dias habiles siguientes a la vacancia	Gerencia General
5. Verificacion completa	El candidato seleccionado completa todas las verificaciones de seccion 5 (antecedentes penales, comerciales, certificaciones, entrevista de seguridad)	Maximo 30 dias habiles	Gerencia General
6. Firma de NDA	El nuevo OS firma el NDA conforme a seccion 6	Antes de asumir funciones	Gerencia General + Asesoría Legal
7. Induccion	Programa de induccion conforme a PE01 seccion 6.1 mas induccion especifica del rol de OS	Maximo 15 dias habiles desde la incorporacion	Gerencia General
8. Notificacion a la Entidad Acreditadora	Notificar a la Subsecretaria de Economia el cambio de OS del PSC conforme a los plazos establecidos por la normativa	Dentro del plazo regulatorio	Gerencia General

8.3 Requisitos del OS interino

El OS interino debe cumplir como minimo:

- Titulo profesional en area de TI o ingenieria.
- Al menos 2 anos de experiencia en seguridad de la informacion.
- Pertenecer al personal de confianza del PSC con verificaciones de antecedentes vigentes (PE01 seccion 7).
- NDA vigente.

La designacion interina no puede extenderse por mas de 90 dias corridos. Si al termino de ese plazo no se ha designado un OS titular, Gerencia General debe informar a la Entidad Acreditadora y presentar un plan de remediacion.

9. Registros y Evidencia

Los siguientes registros deben mantenerse como evidencia de cumplimiento y estar disponibles para auditoria interna y la Entidad Acreditadora:

Registro	Formato	Retencion	Responsable
Expediente de seleccion del OS (antecedentes, verificaciones, entrevista)	Fisico y digital	10 anos desde la desvinculacion del OS	Gerencia General
NDA firmado (original y renovaciones)	Fisico y digital	Indefinido	Asesoría Legal
Certificaciones profesionales vigentes (copias verificadas)	Digital	Mientras el OS ejerza el cargo + 5 anos	Gerencia General
Evaluaciones de desempeno semestrales	Digital	10 anos	Gerencia General
Planes de mejora y su seguimiento	Digital	5 anos	Gerencia General
Informes semestrales de gestion de seguridad del OS	Digital	10 anos	Gerencia General
Acta de designacion interina (si aplica)	Fisico y digital	10 anos	Gerencia General
Acta de traspaso de funciones (si aplica)	Fisico y digital	10 anos	Gerencia General

Registro	Formato	Retencion	Responsable
Notificacion de cambio de OS a la Entidad Acreditadora (si aplica)	Digital	10 anos	Gerencia General
Registro de capacitaciones especializadas del OS	Digital	10 anos desde la desvinculacion	Gerencia General

Todos los registros digitales deben almacenarse en el sistema de gestion documental del PSC con control de acceso restringido exclusivamente a Gerencia General y Auditoria Interna.

Los registros fisicos deben almacenarse en area de acceso controlado conforme a PO04, en sobre sellado con control de apertura.

10. Referencias

Referencia	Descripcion
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
EA-103 v2.1	Guia de Acreditacion de Prestadores de Servicios de Certificacion, seccion 4.24
ISO/IEC 27001:2022	Sistemas de gestion de seguridad de la informacion
ISO/IEC 27002:2022	Controles de seguridad de la informacion (secciones 6.1 a 6.6: controles de personas)
ETSI TS 102 042	Policy requirements for certification authorities issuing public key certificates
ETSI EN 319 411-1	Electronic Signatures and Infrastructures – Policy and security requirements for TSP issuing certificates – Part 1
ETSI EN 319 411-2	Electronic Signatures and Infrastructures – Policy and security requirements for TSP issuing certificates – Part 2 (qualified)
Ley 19.628	Sobre proteccion de la vida privada (datos personales)
Ley 21.459	Sobre delitos informaticos
ISO 19011:2018	Directrices para la auditoria de sistemas de gestion
ISO 31000:2018	Gestion del riesgo – Directrices
NIST SP 800-63-3	Digital Identity Guidelines